Практическая работа № 9

Настройка защищённого подключения к базе данных. Проверка соединения по TLS

1. Цель работы

Научиться проверять защищённость соединения с базой данных PostgreSQL, анализировать параметры TLS, проверять сертификаты и определять, используется ли шифрование при передаче данных между клиентом и сервером.

2. Задачи работы

1. Проверить, включена ли поддержка SSL/TLS на сервере PostgreSQL.
2. Получить сведения о текущем подключении к базе данных.
3. Проверить использование TLS с помощью системного представления `pg_stat_ssl`.
4. Изучить параметры `sslmode` и выбрать безопасный режим подключения.
5. Проанализировать настройки `pg_hba.conf`.
6. Составить рекомендации по организации защищённого подключения.

3. Краткие теоретические сведения

TLS (Transport Layer Security) — протокол, обеспечивающий защиту данных при передаче по сети.

TLS помогает обеспечить:

- **Конфиденциальность** — посторонние не могут прочитать передаваемые данные без ключей.
- **Целостность** — обнаруживаются изменения передаваемых данных.
- **Аутентификацию сервера** — клиент может проверить, что подключается к нужному серверу, а не к подменённому узлу.

В PostgreSQL параметры TLS настраиваются на сервере и клиенте. В современных настройках используется TLS; термин SSL часто встречается в названиях параметров PostgreSQL для совместимости.

Основные значения `sslmode`

Режим	Назначение
`disable`	Не использовать TLS
`allow`	Сначала попробовать соединение без TLS
`prefer`	Предпочесть TLS, но допустить соединение без него
`require`	Требовать шифрование, но не обеспечивать полноценную проверку имени сервера
`verify-ca`	Требовать TLS и проверять сертификат по доверенной цепочке CA

`verify-full`	Требовать TLS, проверять цепочку доверия и соответствие имени сервера сертификату

Для защищённого подключения в типичном клиентском сценарии рекомендуется `sslmode=verify-full`, если сертификат и доверенный CA настроены правильно.

4. Ход выполнения работы

Задание 1. Проверка настроек SSL/TLS сервера

Подключитесь к учебной базе PostgreSQL через pgAdmin или psql и выполните запросы:

```
SHOW ssl;
SHOW config_file;
SHOW hba_file;
```

Что необходимо сделать:

1. Записать результат команды `SHOW ssl;`.
2. Определить, включена ли поддержка SSL/TLS.
3. Указать расположение файлов конфигурации PostgreSQL.
4. Объяснить, для чего используются `postgresql.conf` и `pg_hba.conf`.

Вопрос для анализа: достаточно ли одного значения `ssl = on`, чтобы гарантировать, что конкретный клиент подключился по TLS?

Запишите ответ в отчёт.

Задание 2. Проверка текущего соединения по TLS

Выполните SQL-запрос:

```
SELECT
    a.pid,
    a.usename,
    a.datname,
    a.client_addr,
    s.ssl,
    s.version,
    s.cipher,
    s.bits
FROM pg_stat_activity AS a
JOIN pg_stat_ssl AS s
    ON a.pid = s.pid
WHERE a.pid = pg_backend_pid();
```

Интерпретация результата:

- `ssl = true` — текущее соединение использует SSL/TLS;
- `ssl = false` — текущее соединение не использует SSL/TLS;
- `version` — версия протокола;
- `cipher` — алгоритм шифрования соединения;

- `bits` — длина ключа шифра, если это поле применимо;
- `client_addr` — адрес клиента, если он доступен.

Если значение `ssl` равно `false`, зафиксируйте это в отчёте.

Ответьте на вопросы:

1. Используется ли TLS в текущем соединении?
2. Какая версия протокола отображается?
3. Какой шифр указан в результате?
4. Почему нельзя сделать вывод о безопасности соединения только по факту успешного подключения?

Задание 3. Анализ режимов `sslmode`

Изучите следующие примеры строк подключения.

Пример A:

```
host=db.university.example
port=5432
dbname=university
user=app_user
sslmode=disable
```

Пример B:

```
host=db.university.example
port=5432
dbname=university
user=app_user
sslmode=require
```

Пример C:

```
host=db.university.example
port=5432
dbname=university
user=app_user
sslmode=verify-full
sslrootcert=/path/to/root.crt
```

Для каждого примера заполните таблицу:

Критерий	Пример A	Пример B	Пример C
Требуется шифрование			
Проверяется доверенная цепочка сертификата			
Проверяется имя сервера			
Подходит для защищённого подключения в production			

Объясните, почему режим `verify-full` предпочтительнее, когда требуется проверить не только шифрование, но и подлинность сервера.

Задание 4. Анализ правил доступа `pg_hba.conf`

Изучите пример правила:

```
hostssl university app_user 10.10.10.0/24 scram-sha-256
```

Определите значение каждого элемента:

- `hostssl` — подключение к базе данных по TCP/IP с использованием SSL/TLS;
- `university` — имя базы данных;
- `app_user` — пользователь БД;
- `10.10.10.0/24` — диапазон IP-адресов клиентов;
- `scram-sha-256` — метод парольной аутентификации.

Выполните задания:

1. Объясните, какие клиенты могут соответствовать этому правилу.
2. Укажите, почему `hostssl` полезен для ограничения подключений без TLS.
3. Объясните, почему необходимо проверять остальные правила `pg_hba.conf` и их порядок.
4. Предложите два дополнительных способа защиты подключения.

Важно: одно правило `hostssl` само по себе не гарантирует, что все остальные способы подключения к серверу запрещены. Нужно проверить весь набор правил и сетевые ограничения.

Задание 5. Разработка схемы защищённого подключения

Представьте, что информационная система университета подключается к базе данных PostgreSQL с персональными данными студентов.

Разработайте краткий план безопасного подключения.

В плане должны быть отражены следующие пункты:

1. На сервере PostgreSQL включена поддержка TLS.
2. Сервер использует действующий сертификат и соответствующий закрытый ключ.
3. Клиент доверяет нужному центру сертификации.
4. В клиентском подключении установлен режим `sslmode=verify-full`.
5. Имя сервера совпадает с именем, указанным в сертификате.
6. В `pg_hba.conf` разрешены подключения только необходимым пользователям и сетям.
7. Для приложения создана отдельная учётная запись с минимально необходимыми правами.
8. Сетевой доступ к порту PostgreSQL ограничен межсетевым экраном.
9. Организованы контроль срока действия и своевременное обновление сертификатов.

Пример клиентской конфигурации:

```
host=db.university.example
port=5432
```

```
dbname=university
user=app_user
sslmode=verify-full
sslrootcert=/path/to/root.crt
```

Результат: оформите схему подключения в виде последовательности:

Клиент приложения → проверка сертификата сервера → защищённое TLS-соединение → аутентификация пользователя PostgreSQL → проверка прав доступа → работа с базой данных.